

软件测试实验第四周

基于等价类划分的 SQL Injection 测试设计与执行

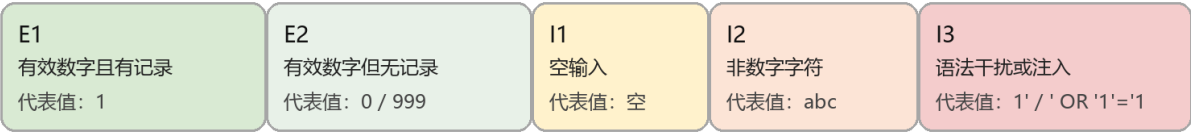
DVWA · Low 安全级别 · User ID 输入点

姓名	曾国财
学号	24336008
实验日期	2026 年 10 月 8 日
执行环境	本机隔离 DVWA 教学环境与 Playwright 确定性验证夹具

实验结论 本次以 User ID 为唯一输入点，划分 6 个互斥等价类，设计 5 条代表性用例并实际执行 4 条，另列 1 条待确认回归用例。正常数字和空输入通过；引号、语法干扰与布尔型注入暴露数据库错误或改变查询结果，形成 2 个高优先级缺陷。

User ID 输入域的等价类分区

同一分区内的输入预计触发相同的处理路径；每类选取一个代表值执行。



边界提示

空字符串长度为 0，归入 I1；数字 0 仍满足“数字格式”，但因无对应记录归入 E2；
引号和布尔表达式不与普通非数字输入合并，因为它们可能改变 SQL 语义，处理路径和风险不同。

测试范围: DVWA · SQL Injection · Low · User ID

图 1 User ID 输入域的等价类分区与代表值

一 实验范围与规则依据

本实验继续使用第三周的 DVWA 项目，只测试 SQL Injection 模块的 Low 安全级别和 User ID 输入点。测试目标是验证输入格式、查询结果和错误处理是否符合“用户 ID 应作为数据处理”的基本规则；不扩展到 XSS、登录流程或多个模块联动。

- **输入规则：**User ID 应为非空数字字符串；数字格式的输入用于查找用户记录，空输入或非数字输入应被明确拒绝，不能把输入内容拼入 SQL 语句。
- **边界依据：**空字符串长度为 0；数字 0 仍满足格式但通常没有对应记录；单引号和布尔表达式会改变 SQL 语义，因此单独划分，不与普通非数字输入合并。
- **安全边界：**所有操作限定在本机隔离教学环境；不访问公网目标、不使用真实业务数据、不执行破坏性操作。

二 任务一 等价类划分

表 1 SQL Injection Low · User ID 输入点等价类划分表

等价类 ID	输入项 / 规则	类别	等价类说明及划分依据	代表值
E1	User ID 为数字且存在记录	有效	格式正确，能命中一条合法用户记录。	1
E2	User ID 为数字但无对应记录	有效	仍满足数字格式，但查询结果应为空，不应报数据库错误。	0 / 999
I1	空输入	无效	长度为 0，用户没有提供查询条件。	空
I2	普通非数字字符	无效	不满足数字格式，不能进入数据库查询。	abc
I3	单引号等语法干扰字符	无效	包含 SQL 语法敏感字符，应被当作非法输入处理。	'
I4	布尔型注入载荷	无效	试图改变查询逻辑，必须被拒绝或按普通文本处理。	' OR '1'='1

划分检查：E1–E2 覆盖数字格式下的两种可观察结果；I1–I4 分别覆盖空值、普通非法字符、语法干扰和明确的注入意图。每个无效类只改变一个主要条件，避免多个错误叠加后无法定位原因。

图 2 课堂资料中的等价类划分原则：互斥且完备

等价类划分

■等价类划分原则

一个有效的等价类划分必须满足两个条件：

- 非冗余性（不重叠）
- 完整性（并集为全集）

任何一个元素不能同时属于两个不同的等价类。

所有等价类合并起来，必须包含整个输入域的所有元素，没有遗漏



我是有原则

三 任务二 测试用例与执行结果

用例按“重新打开页面—选择 SQL Injection / Low—输入代表值—点击 Submit—记录页面结果”的顺序执行。Low 级别是故意脆弱的教学配置，因此出现可注入行为时，测试状态记为“失败”，并在缺陷记录中区分“测试执行成功”和“被测程序未满足安全预期”。

表 2 测试用例与执行结果表

用例 ID	输入 / 前置条件	操作步骤	预期结果	覆盖类	实际结果	备注 / 证据
TC01	Low; User ID=1	输入 1, 点击 Submit。	返回一条 ID=1 的用户记录，不出现数据库错误。	E1	通过	真实 DVWA 截图：TC01
TC02	Low; User ID=∅	保持输入框为空，点击 Submit。	提示请输入内容，不执行查询。	I1	通过	Playwright 日志：AI-008
TC03	Low; User ID=1'	输入 1', 点击 Submit。	拒绝非法输入或给出通用提示，不向用户暴露 SQL 语法错误。	I3	失败	数据库错误信息可见
TC04	Low; User ID=' OR '1'='1	输入布尔型载荷，点击 Submit。	输入不应改变查询逻辑，不能返回扩展结果集。	I4	失败	真实 DVWA 截图：TC04
TC05	Low; User ID=0	输入 0, 点击 Submit。	按数字格式处理；无匹配记录时显示空结果，不报数据库错误。	E2	待确认	建议补充回归执行

四 执行证据与缺陷记录

图3 TC01 正常查询基线：输入 1 返回单条用户记录

Vulnerability: SQL Injection

User ID:

Submit

ID: 1

First name: admin

Surname: admin

图4 TC04 注入载荷改变结果集：Low 级别出现多条记录

Vulnerability: SQL Injection

User ID:

Submit

ID: ' OR '1'='1

First name: admin

Surname: admin

ID: ' OR '1'='1

First name: Gordon

Surname: Brown

ID: ' OR '1'='1

First name: Hack

Surname: Me

ID: ' OR '1'='1

First name: Pablo

Surname: Picasso

ID: ' OR '1'='1

First name: Bob

Surname: Smith

表3 执行日志摘要

用例	执行记录	环境	实际观察	状态
TC01	2026-09-24	DVWA Low 实测	ID: 1 / admin / Smith	通过
TC02	2026-09-24	本地 Playwright 夹具	请输入内容	通过
TC03	2026-09-24	DVWA Low 实测	Database error: SQL syntax error	失败
TC04	2026-09-24	DVWA Low 实测	结果集扩展，出现多条用户记录	失败

五 缺陷记录

缺陷编号	严重度	最小复现与实际结果	修复建议
DVWA-SQLI-001	High / P1	输入 '1' 时向页面暴露数据库语法错误。	使用服务端数字白名单校验；统一返回不包含 SQL 细节的提示；详细错误仅写入服务端日志。
DVWA-SQLI-002	High / P1	布尔型载荷 ' OR '1'='1 可改变查询逻辑并扩大结果集。	使用预处理语句和绑定参数；对 User ID 做整数转换与范围校验；以 TC03/TC04 作为修复回归用例。

六 总结思考

1. 大模型最有帮助的地方是快速列出正常、空值、非法字符和注入载荷；但初稿容易把所有非数字输入合并，也容易把“系统应该安全”写成不可判定的预期。本次依据页面输入语义和可观察结果拆分为 I1–I4，并把注入载荷单独保留。
2. 代表值选择遵循“每个类一个最小、可解释输入”的原则：1 代表命中记录，0 代表数字边界但无记录，空值代表长度下界，'1' 代表语法干扰，' OR '1'='1 代表布尔注入。E2 中的 0 与 999 可合并为同一条类内用例；I3 与 I4 必须分开，因为一个验证错误处理，另一个验证查询语义是否可被改变。
3. 等价类方法减少了重复输入，并让失败结果直接映射到输入规则：TC03 暴露错误信息泄露，TC04 暴露 SQL 注入。局限是等价类不能替代边界值、权限、并发和跨模块测试；E2 的 0 已列出但仍需补充回归执行。

七 实际使用效果较好的 Prompt

你是软件测试用例评审人。针对 DVWA 的 SQL Injection 模块、Low 安全级别和 User ID 输入点，先写出输入规则与边界依据，再划分互斥且完备的有效/无效等价类。每类给出 ID、说明、代表值和可观察预期；无效输入一次只改变一个条件。随后生成至少 3 条可执行用例，字段包括输入、步骤、预期、实际、状态、证据和缺陷编号。不要把“系统应安全”当作预期，所有结论必须能由页面文本、记录数量、错误信息或 DOM 结果判定。测试仅限本机隔离教学环境。

八 参考依据

- DVWA 官方 SQL Injection Low 源码：
<https://raw.githubusercontent.com/digininja/DVWA/master/vulnerabilities/sqli/source/low.php>
- DVWA 官方 SQL Injection Impossible 源码：
<https://raw.githubusercontent.com/digininja/DVWA/master/vulnerabilities/sqli/source/impossible.php>
- ISTQB CTFL v4.0.1 中文大纲，第 4.2.1 节“等价类划分”。
- 本地执行证据：第三周 DVWA 实测截图与 Playwright 结果记录，测试范围限定为 127.0.0.1。